SKILLNAVORA · AI PRODUCT MANAGEMENT & GENAI LAUNCHPAD

AI Governance & Responsible AI

Ship AI responsibly: principles and risks, regulations (EU AI Act, India's DPDP Act and AI guidelines, sector rules), AI risk and impact assessments, policies and documentation, and operating governance.

Edition 2026 · skillnavora.in

How to use this guide

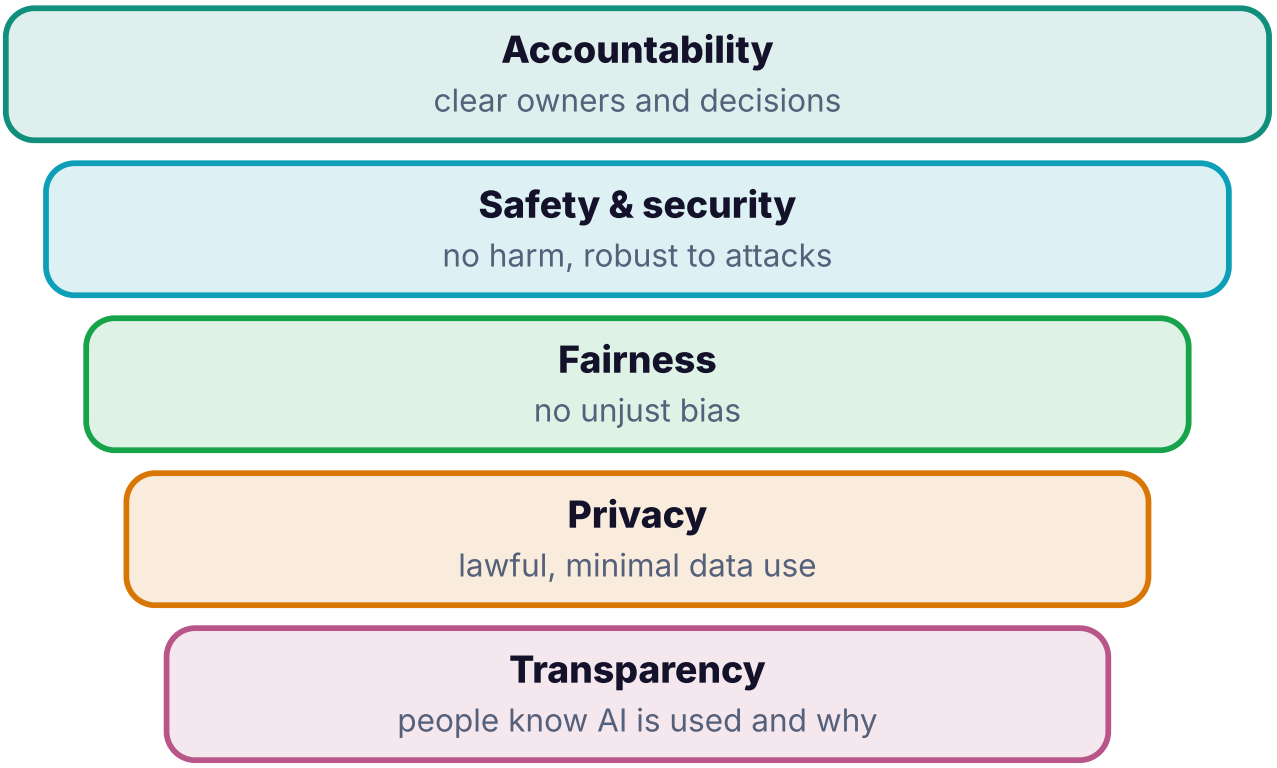
Each class has goals, concepts with Indian examples, key takeaways and a practice exercise, from basic to advanced. Finish with the final project to build something you can show in interviews.

	Class	Level
Class 1	**Principles and risks**	Basic
Class 2	**Regulations to know**	Basic
Class 3	**AI risk and impact assessment**	Intermediate
Class 4	**Policies and documentation**	Intermediate
Class 5	**Fairness, bias and explainability**	Intermediate
Class 6	**Privacy, security and AI-specific attacks**	Intermediate
Class 7	**Operating governance**	Advanced
Class 8	**Red teaming, evaluation and monitoring for safety**	Advanced
Class 9	**Vendor due diligence, procurement and third-party AI**	Advanced
Class 10	**Building a responsible-AI programme and culture**	Advanced
Class 11	**Case studies: three governance decisions**	Advanced
Class 12	**Interview practice: governance scenario questions**	Advanced
Class 13	**Final project**	Advanced
	Toolkit: templates, cheat sheet, glossary, 15 interview questions, further reading	

BASIC · CLASS 1

Principles and risks

Know the main responsible-AI principles and risks.



Responsible AI principles

Typical risks: harmful or wrong outputs, bias, privacy leaks, IP/copyright, security (prompt injection), over-reliance, and job or social impact.

AI risk map

Risk	Example	Typical control
Bias and unfair outcomes	Loan model approves fewer applicants from a region	Fairness tests, diverse data, human review
Privacy and data leakage	Chatbot reveals another customer's details	Access controls, redaction, no-training agreements, retention limits
Hallucination and misinformation	Assistant invents a refund policy	Grounding, citations, evals, disclaimers
Security	Prompt injection makes an agent send data out	Input and output filtering, least-privilege tools, red teaming
Safety and misuse	Generating harmful content	Policy filters, monitoring, rate limits
IP and copyright	Output copies protected material	Licensed data, content filters, review
Opacity and accountability	No one can explain a decision	Logs, documentation, explainability where needed
Operational and vendor	Provider changes a model, quality drops	Versioning, regression evals, exit plans

Key takeaways

- Principles must turn into checks.
- List risks per feature.
- Name an accountable owner.

Practice exercise: List the top 5 risks of an AI hiring-screening feature.

BASIC · CLASS 2

Regulations to know

Understand the main laws and frameworks at a PM level.

Framework	What PMs should know
EU AI Act	Risk tiers: prohibited, high-risk (e.g. hiring, credit), limited-risk (transparency duties like disclosing chatbots), minimal; obligations phase in over several years
India: DPDP Act 2023	Consent, purpose limitation, data minimisation, rights of data principals; applies to personal data used in AI
India: government AI guidance	Advisories and governance guidelines on responsible AI, deepfakes and labelling; check current versions
Sector rules	RBI (lending, fraud), SEBI (investment advice), IRDAI (insurance), health regulators
Standards	NIST AI Risk Management Framework; ISO/IEC 42001 AI management systems

This is a learning summary, not legal advice; involve legal counsel for real decisions.

Regulation quick map (check current rules; these change)

Framework	Applies to	Key idea for PMs
EU AI Act	AI systems offered or used in the EU	Risk tiers: banned practices, high-risk (strict duties: risk management, data quality, logging, human oversight, transparency), limited-risk (transparency such as telling users they talk to AI), minimal risk. General-purpose AI model providers have their own duties. Obligations phase in over several years.
India DPDP Act 2023 and Rules	Personal data of people in India	Consent and notice, purpose limitation, data minimisation, security safeguards, breach reporting, rights of data principals, children's data restrictions
India IT Rules and advisories	Online platforms and intermediaries	Due diligence on harmful content, labelling and takedown obligations; advisories on deepfakes and AI-generated content
RBI / SEBI / IRDAI guidance	Banks, NBFCs, brokers, insurers	Model risk management, outsourcing, explainability for credit, data localisation for payments
NIST AI RMF (US, voluntary)	Any organisation	Govern, Map, Measure, Manage: a practical risk framework
ISO/IEC 42001	Organisations running AI	A certifiable AI management system standard
GDPR (EU)	Personal data of people in the EU	Lawful basis, rights, automated decision-making rules, DPIAs

> This is orientation, not legal advice. Ask counsel which rules apply to your product, markets and data, and check dates because AI regulation is changing quickly.

Key takeaways

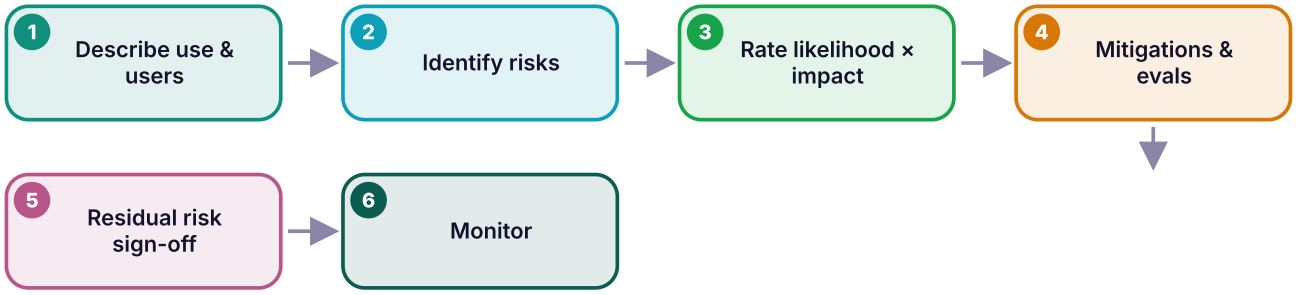
- Know your feature's risk tier.
- Personal data → DPDP duties.
- Check sector regulators and current guidance.

Practice exercise: Classify 5 AI features by EU AI Act risk tier and explain.

INTERMEDIATE · CLASS 3

AI risk and impact assessment

Assess a feature before launch.



AI risk assessment

Use evals and red-teaming results as evidence for each mitigation.

Risk tiering example

Tier	Examples	Required reviews
High	Credit decisions, hiring, health triage, anything affecting rights or safety	Full impact assessment, legal review, bias testing, human oversight, audit logs, pre-launch sign-off
Medium	Customer-facing chatbots, personalised pricing nudges	Risk review, evals, disclosure, monitoring
Low	Internal drafting aids, summarisation with review	Lightweight checklist and owner sign-off

Key takeaways

- Assess before launch, not after incidents.
- Evidence = evals and red-team results.
- Sign off residual risk explicitly.

Practice exercise: Complete a risk assessment for an AI loan-eligibility assistant.

INTERMEDIATE · CLASS 4

Policies and documentation

Write the documents governance needs.

- Company AI use policy (what tools, what data, approvals).
- Model/system cards: purpose, data, evaluation, limits, contacts.
- Data protection impact assessment for personal data.
- User-facing disclosures: "You're chatting with AI", AI-generated labels.
- Decision logs for high-impact choices.

Documents every AI feature should have

Document	What it contains
Model / system card	Purpose, model and version, data sources, limits, known failure modes, eval results, intended and prohibited use
Data sheet	Where data came from, consent and licence, quality, bias checks, retention
Risk assessment	Hazards, likelihood and impact, mitigations, residual risk and owner
DPIA / privacy impact	Personal data used, purpose, necessity, safeguards
Human oversight plan	Who reviews what, escalation, override powers
Incident runbook	How to detect, contain, communicate, fix and learn
Change log	Model and prompt changes with evals and approvals

Key takeaways

- Document purpose, data, evals and limits.
- Disclose AI to users.
- Keep decision logs.

Practice exercise: Draft a 1-page AI use policy for a 50-person startup.

INTERMEDIATE · CLASS 5

Fairness, bias and explainability

Test whether AI treats groups fairly and can explain itself.

Bias enters through **data** (who is represented), **labels** (human judgments), **features** (proxies such as pincode for caste or income) and **deployment** (who uses the system and how).

Fairness idea	Plain meaning	Example check
Demographic parity	Similar positive rates across groups	Loan approval rate by gender and region
Equal opportunity	Similar true positive rates	Among creditworthy applicants, share approved by group
Calibration	Scores mean the same across groups	A 70% risk score reflects 70% observed risk in each group
Error-rate balance	Similar false positives and negatives	Fraud flags wrongly raised on one group more often

- These measures can conflict; choose using the harm, law and context, and document why.
- Test on slices (language, region, device, gender where lawful and ethical to measure) not only overall accuracy.
- **Explainability:** give reasons users can act on ("your income documents were incomplete") and keep logs for audits. Use simple models for high-stakes decisions where possible.
- **Appeal and redress:** users should be able to contest and reach a human.

Key takeaways

- Test performance by slice, not only overall.
- Fairness measures can conflict; document the choice.
- Give actionable reasons and a way to appeal.

Practice exercise: Design a fairness test plan for a loan-eligibility model, listing slices, metrics and thresholds.

INTERMEDIATE · CLASS 6

Privacy, security and AI-specific attacks

Protect user data and the AI system itself.

Privacy by design for AI

- **Minimise:** send only needed fields to the model; mask PAN, Aadhaar, phone numbers.
- **Purpose limitation:** use data only for the stated purpose; get consent for new uses.
- **Vendors:** data processing agreements, no training on your data, retention and deletion, location of processing.
- **Rights:** access, correction, deletion; can you remove a person from logs, embeddings and fine-tuning data?

AI-specific security threats

Threat	What happens	Defence
Prompt injection	Hidden instructions in a web page or document hijack the model	Separate instructions from data, filter, least-privilege tools, human approval for risky actions
Data exfiltration	Model leaks secrets or other users' data	Access controls on retrieval, redaction, output checks
Jailbreaks	Users bypass safety rules	Layered filters, monitoring, red teaming
Training data poisoning	Bad data corrupts a model	Source vetting, review, anomaly detection
Model theft or abuse	Scraping, high-volume misuse	Rate limits, auth, monitoring
Supply-chain risk	Compromised plugins, models or packages	Vendor reviews, pinned versions, scanning

> Treat an AI agent like a junior employee with a master key: give it only the access it needs, log everything, and require approval for actions that move money or data.

Key takeaways

- Minimise and mask data before it reaches the model.
- Prompt injection is the top new threat for agents.
- Least privilege and logs for every tool.

Practice exercise: Run a threat model for an AI support agent that can issue refunds.

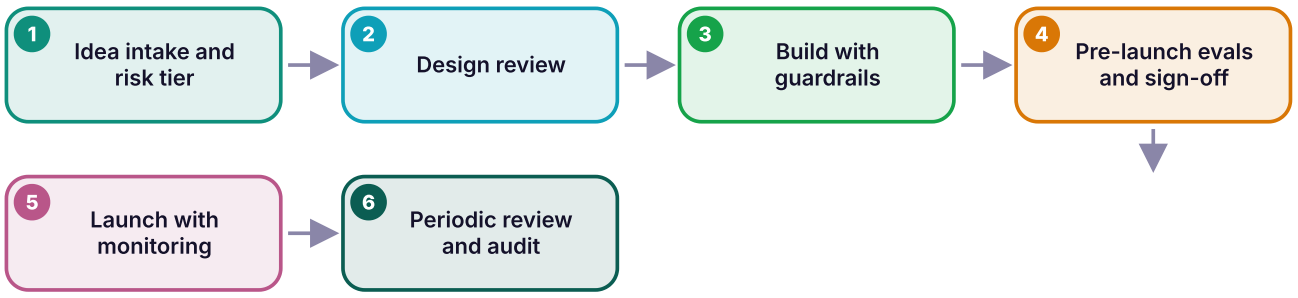
ADVANCED · CLASS 7

Operating governance

Run governance without slowing teams down.

- Tiered review: light checklist for low-risk features, committee review for high-risk.
- Incident response: report, triage, rollback, communicate, learn.
- Audits: periodic eval and bias re-checks, access reviews.
- Vendor management: data terms, security, model changes.

Governance in the lifecycle



Governance gates across the AI product lifecycle

Key takeaways

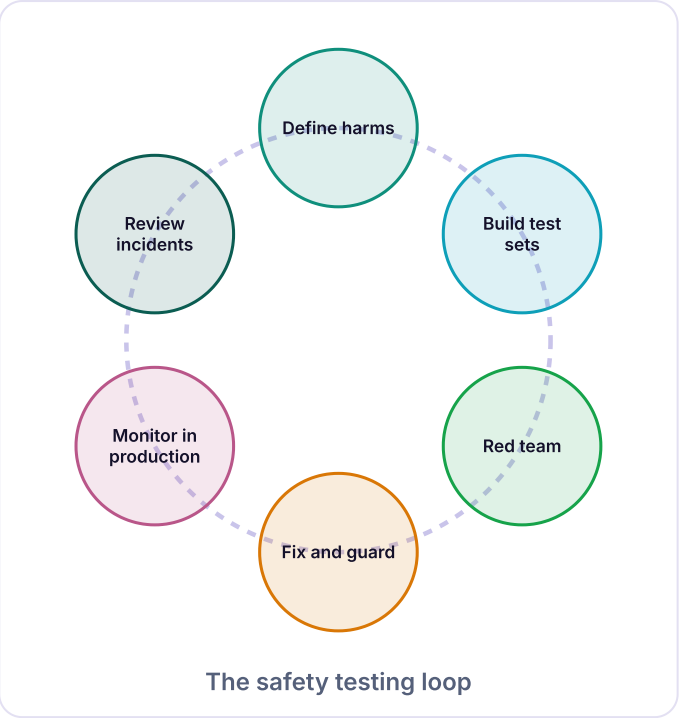
- Tier the process by risk.
- Have an incident playbook.
- Re-check periodically.

Practice exercise: Design a tiered AI review process for your company.

ADVANCED · CLASS 8

Red teaming, evaluation and monitoring for safety

Test for harm before and after launch.



The safety testing loop

- **Define harms:** list what could go wrong for users, the company and third parties (misinformation, harassment, privacy leaks, unsafe advice, discrimination).
- **Build test sets:** adversarial prompts, edge cases, multilingual and Hinglish inputs, sensitive topics.
- **Red team:** internal and external testers try to make the system fail; record findings and severity.
- **Guardrails:** input and output filters, refusal policies, grounding, rate limits, human escalation.
- **Monitor:** sampled reviews, user reports, drift in quality, harmful-output rates, complaint themes.
- **Incident response:** severity levels, kill switch, owner on call, user communication, regulator notification where required, post-incident review.

Metric	Example target
Harmful output rate on red-team set	Below an agreed threshold, with zero critical failures
Refusal correctness	Refuses unsafe requests, answers safe ones
Escalation time for severe incidents	Under 1 hour to contain
User reports resolved	Within an agreed time

Key takeaways

- Test harms before launch and monitor after.
- Keep a kill switch and an incident runbook.
- Cover multilingual and adversarial cases.

Practice exercise: Draft a red-team test plan with 20 adversarial prompts for an AI assistant in your domain.

ADVANCED · CLASS 9

Vendor due diligence, procurement and third-party AI

Check AI suppliers before you rely on them.

Area	Questions to ask
Data	Is our data used for training? Retention? Location? Deletion on request? Sub-processors?
Security	Certifications (ISO 27001, SOC 2), pen tests, incident history, access controls
Model	Which model and version? Change notifications? Deprecation policy? Evaluation reports?
Legal	IP indemnity, liability caps, audit rights, compliance with DPDP and other laws
Reliability	SLA, uptime history, rate limits, support
Exit	Data export, switching cost, escrow or fallback
Responsible AI	Policies, red-team practice, transparency, content provenance

Create a **standard questionnaire**, risk-rate each vendor, keep a register of AI tools in use (including shadow AI used by employees) and review annually.

Key takeaways

- Use a standard vendor questionnaire.
- Know which AI tools are in use, including unofficial ones.
- Plan exit before you sign.

Practice exercise: Create an AI vendor due diligence checklist and rate two tools you use.

ADVANCED · CLASS 10

Building a responsible-AI programme and culture

Make governance practical and lasting.

- **Principles to practice:** turn values (fairness, transparency, privacy, safety, accountability) into checklists, tests and owners.
- **Structure:** an AI governance committee for high-risk cases, product-level owners, and a lightweight intake process so teams are not blocked.
- **Policies:** acceptable use for employees (what data may go into public AI tools), AI procurement, human oversight, disclosure to users, incident handling.
- **Training:** role-based, for PMs, engineers, support and executives.
- **Transparency:** tell users when they interact with AI, how their data is used, and how to reach a human.
- **Metrics:** percent of AI features with risk assessment, evals, monitoring; open issues by severity; incidents and time to resolve; training completion.
- **Culture:** reward people for raising risks; run blameless reviews; make the safe path the easy path.

> Good governance speeds teams up by making the rules clear and the reviews predictable. Bad governance is a late-stage veto.

Key takeaways

- Turn principles into checklists, tests and owners.
- Keep intake light; reserve deep review for high risk.
- Measure coverage and incident handling.

Practice exercise: Draft a one-page AI acceptable-use policy for employees.

ADVANCED · CLASS 11

Case studies: three governance decisions

Apply governance to practical situations (illustrative).

Case 1: Loan approval model shows regional gap

- **Finding:** approval rate is 18 points lower in one region at similar income levels.
- **Investigation:** a proxy feature (pincode-based risk score) drives the gap; data coverage is poor there.
- **Actions:** remove or adjust the proxy, add alternative data with consent, set fairness thresholds, human review for borderline cases, and document the decision for audit.
- **Monitor:** monthly slice metrics; report to the governance committee.

Case 2: Employees paste customer data into a public chatbot

- **Risk:** personal data leaves the company; possible DPDP breach.
- **Actions:** acceptable-use policy, approved tools with enterprise terms, data loss prevention, training, and logging; provide a safe alternative so people do not use shadow AI.

Case 3: Support bot gives a wrong refund policy

- **Severity:** medium; customers affected; brand risk.
- **Response:** kill switch for the policy topic, correct the knowledge base, add a citation requirement and an eval for refund questions, notify affected customers, and run a blameless review.

Key takeaways

- Investigate causes before choosing fixes.
- Provide safe alternatives to prevent shadow AI.
- Keep incident response ready.

Practice exercise: Choose a case and write the governance memo: finding, risk, actions, owner, date.

ADVANCED · CLASS 12

Interview practice: governance scenario questions

Answer responsible-AI questions clearly.

Q. How would you launch an AI feature responsibly?
Model answer: I would risk-tier it, run an impact assessment, document data and model limits, test fairness and safety with red-team sets, add guardrails, human oversight and disclosure, plan monitoring and an incident runbook, and get the required sign-offs before a staged rollout.
Why it works: It follows the lifecycle.

Q. Regulators ask how your model makes decisions. What do you provide?
Model answer: Model documentation, data sources and quality checks, evaluation and fairness results, human oversight procedures, logs of decisions and changes, and the risk assessment with mitigations.
Why it works: Evidence-based.

Q. How do you balance innovation speed and governance?
Model answer: Use risk-based tiers: lightweight checks for low-risk features, deeper reviews for high-risk, automate checks in pipelines, and make policies clear so teams know what is required.
Why it works: Speed through clarity.

Q. What are the biggest AI risks for a consumer app?
Model answer: Wrong or harmful outputs, privacy leakage, bias, security attacks such as prompt injection, IP issues and over-reliance by users; mitigated through evals, guardrails, access controls, transparency and monitoring.
Why it works: Complete risk map.

Key takeaways

- Follow the lifecycle: assess, test, guard, monitor, review.
- Use tiers to keep speed.
- Prepare evidence.

Practice exercise: Write answers to all four in your own words.

ADVANCED · CLASS 13

Final project

Govern a real AI feature.

For an AI feature, produce: risk tier, risk assessment table, mitigations with eval evidence, system card, user disclosure copy, DPDP checklist, incident playbook.

Key takeaways

- Governance is a product practice.
- Evidence over promises.
- Make it lightweight for low risk.

Practice exercise: Complete the governance pack.

TOOLKIT

Templates

AI risk register

```
risk | feature | likelihood (1-5) | impact (1-5) | mitigation | eval evidence | owner |
status
```

TOOLKIT

Cheat sheet

Term / tool	Meaning / use
EU AI Act	EU law with risk-based AI obligations
DPDP Act	India's Digital Personal Data Protection Act, 2023
NIST AI RMF	US framework for AI risk management
ISO/IEC 42001	AI management system standard
System card	Document describing an AI system's purpose and limits
Tiering	High, medium, low risk decides depth of review
Docs	Model card, data sheet, risk assessment, runbook
Safety loop	Define harms, test, guard, monitor, review
Agent rule	Least privilege plus logs plus approval for risky actions

Glossary

Residual risk	Risk left after mitigations
Red-teaming	Trying to make the AI fail
Red teaming	Adversarial testing to find failures
Model card	Document describing a model and its limits
DPIA	Data protection impact assessment
Prompt injection	Hidden instructions that hijack a model
Demographic parity	Equal outcome rates across groups
Human in the loop	A person reviews or approves AI actions
Guardrail	A rule or filter limiting model behaviour
Shadow AI	AI tools used without approval
NIST AI RMF	US voluntary framework: Govern, Map, Measure, Manage
ISO/IEC 42001	AI management system standard
Data principal	The person whose personal data is processed (DPDP term)
Kill switch	A way to disable a feature quickly

INTERVIEW PREP

15 interview questions with answers

Q1. What is responsible AI?
Building AI that is accountable, safe, fair, private and transparent, backed by processes and evidence.

Q2. How does the EU AI Act affect products?
Obligations depend on risk tier; high-risk uses like hiring or credit need risk management, data governance, documentation and human oversight.

Q3. What does DPDP mean for AI features?
Lawful consent/purpose, minimal data, user rights, security, and care with personal data in prompts and logs.

Q4. How do you run a risk assessment?
Describe use, identify risks, rate them, add mitigations with eval evidence, sign off residual risk, monitor.

Q5. How do you keep governance fast?
Tiered reviews, templates, automation of checks, clear owners.

Q6. What is responsible AI?
Building and operating AI so it is fair, safe, private, transparent and accountable, with controls that match the risk.

Q7. What are the EU AI Act's risk tiers?
Unacceptable risk (banned), high risk (strict obligations), limited risk (transparency duties) and minimal risk. Providers of general-purpose models have additional obligations.

Q8. How does India's DPDP Act affect AI products?
It requires consent and notice, purpose limitation, data minimisation, security and breach reporting, and gives people rights over their data, which affects training data, logs and retention.

Q9. How would you test an AI feature for bias?
Define slices, choose fairness metrics relevant to the harm, compare error rates and outcomes across slices, investigate causes, mitigate, and document.

Q10. What is prompt injection and how do you defend against it?
Malicious instructions hidden in content the model reads. Defend with separation of instructions and data, least-privilege tools, filtering and human approval for risky actions.

Q11. What is a model card?
A document describing a model's purpose, data, performance, limits and intended use, used for transparency and review.

Q12. How do you handle an AI incident?
Detect, contain (kill switch), assess severity, communicate to affected users and regulators if required, fix, and run a blameless review.

Q13. What would you ask an AI vendor before signing?
Data use and retention, security certifications, model change policy, IP indemnity, SLAs, exit options and responsible-AI practices.

Q14. How do you balance speed and governance?
Risk-tier features, use lightweight checklists for low risk, reserve deep review for high risk, and

embed governance in the delivery process.

Q15. When should a human stay in the loop?
For decisions affecting rights, money, safety or health, for low-confidence outputs, and for novel or sensitive cases.

LEARN MORE

Further reading and tools

- EU AI Act overview ↗
- NIST AI Risk Management Framework ↗
- ISO/IEC 42001 ↗
- India DPDP Act (MeitY) ↗
- OECD AI principles ↗
- NIST AI Risk Management Framework ↗
- EU AI Act overview ↗
- India DPDP Act (MeitY) ↗
- OECD AI Principles ↗

© SkillNavora · skillnavora.in · Part of the AI Product Management and GenAI Launchpad programs. Practise with the free AI Tutor, AI PM Toolkit and Practice Lab on skillnavora.in.